



Authentification LDAP et LDAPS

A- Test de la connectivité LDAP et LDAPS (LDAP sur SSL) sur le serveur active directory hermes

1- Connectivité LDAP

2- Connectivité LDAPS (LDAP sur SSL)

a- Création d'une autorité de certification sur le contrôleur de domaine hermes

i- Ajouter le rôle certificat sur hermes

ii- Configuration du rôle certificat sur hermes

B- Test de la connectivité LDAP et LDAPS (LDAP sur SSL) sur heimdall (pfsense)

C- Création des comptes utilisateurs sur le contrôleur de domaine

D- Création des authentifications LDAP et LDAPS sur le serveur pfsense

E- Création de l'authentifications LDAP

1- Création de l'authentifications LDAP

2- Création de l'authentifications LDAPS

a- Création du formulaire de l'authentification LDAPS

b- Analyse avec Wire Shark du trafic pfsense active directory

c- Exportation du certificat de l'autorité de certification hermes

d- Importation du certificat de l'autorité de certification racine

e- Test de la connexion ssl entre pfsense et le contrôleur de domaine

3- Utilisation des authentifications LDAP et LDAPS sur le serveur pfsense

a- Vérification de l'authentification LDAP et LDAPS

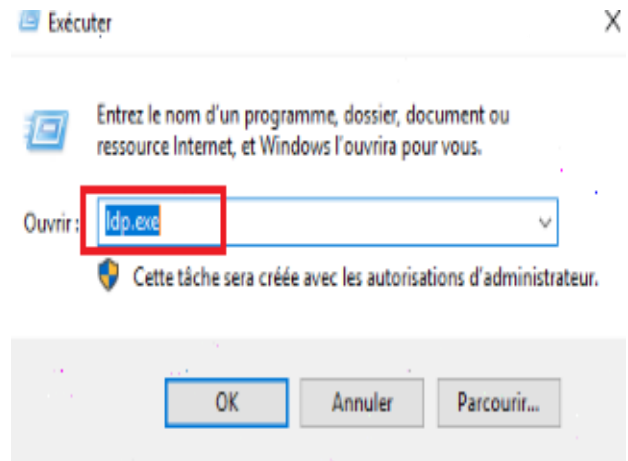
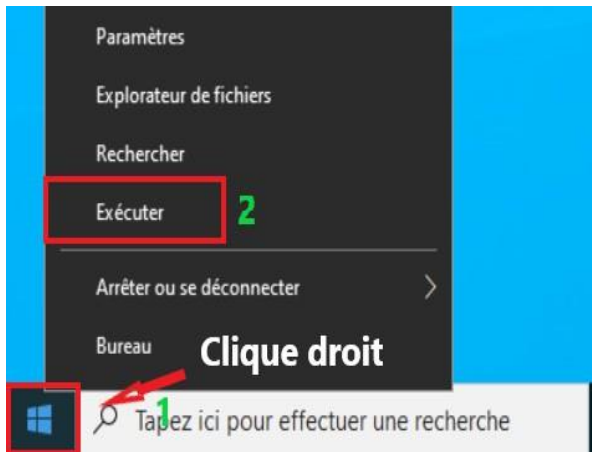
b- Création et configuration d'un groupes sur pfsense

c- Test de connexion sur l'interface web avec un compte ldap

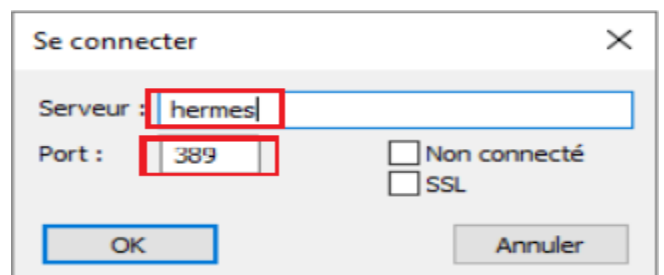
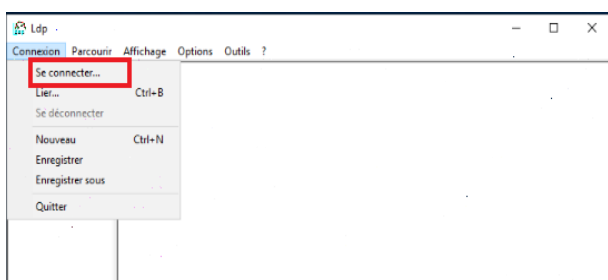
A- Test de la connectivité LDAP et LDAPS sur le serveur active directory hermes

1- Connectivité LDAP

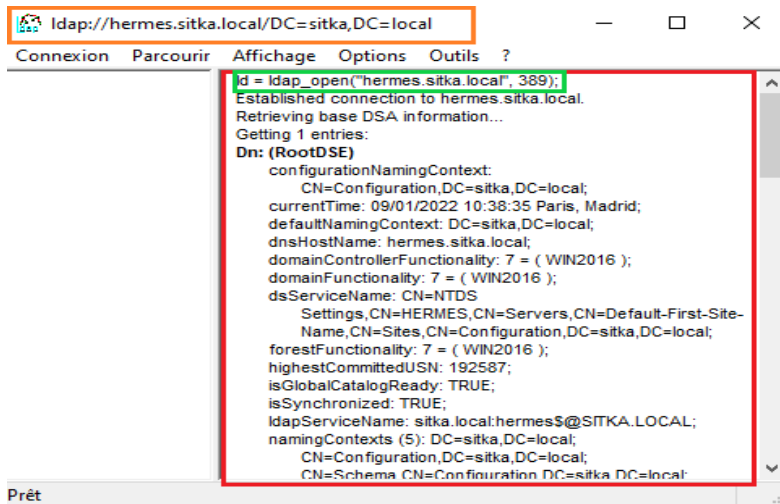
Sur le contrôleur de domaine on test la connectivité LDAP standard, donc clique droit sur le menu démarrer + exécuter puis on tape ldp.exe pour ouvrir l'explorateur LDAP



Un fois l'explorateur LDAP est ouvert l'explorateur on choisit le menu Se connecter et on rentre le nom du serveur **hermes.sitka.local** ainsi que le port de connexion **389**

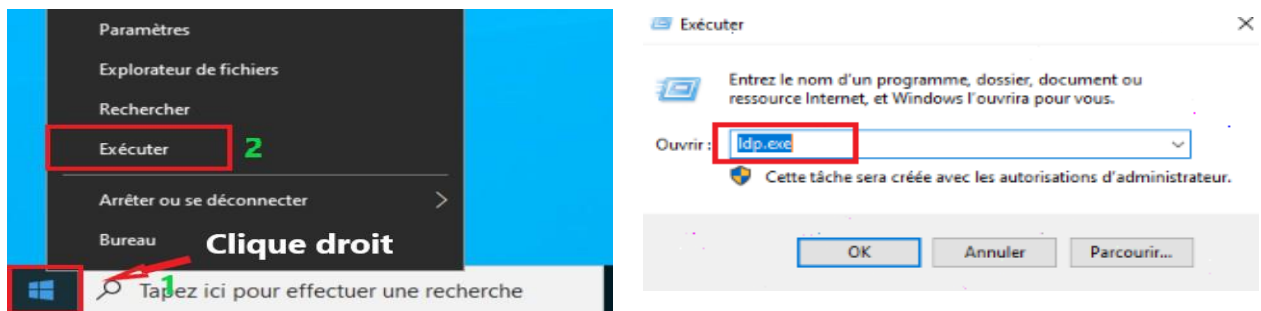


La connexion à la base d'annuaire fonctionne on peut identifier les partitions d'annuaire

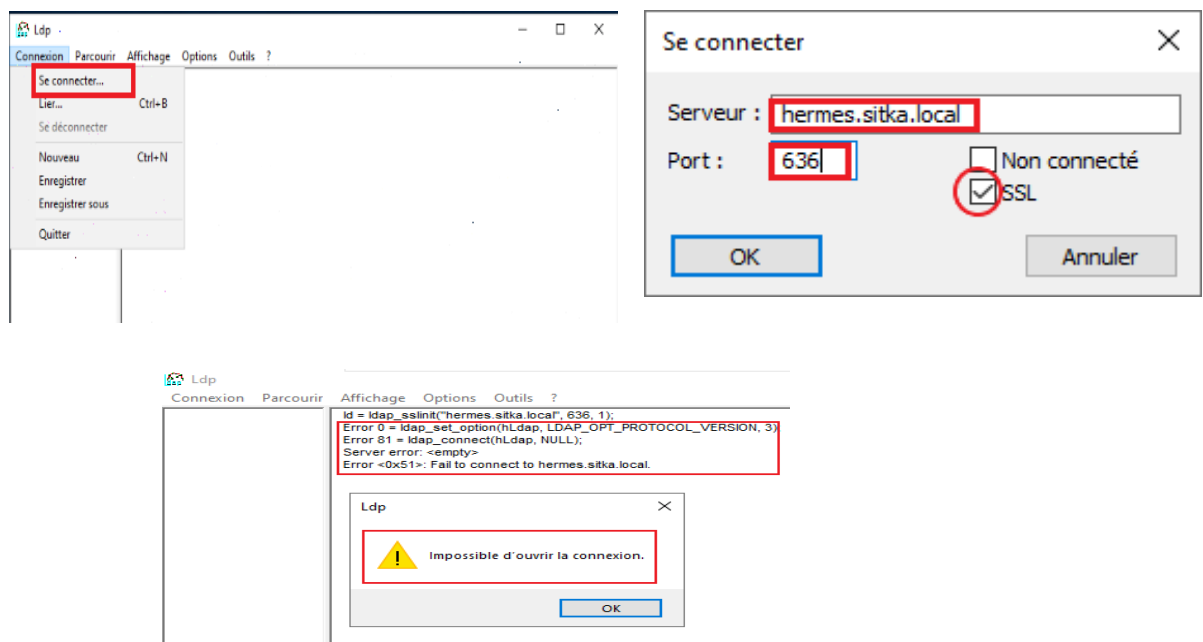


2- Connectivité LDAPS (LDAP sur SSL)

On fait la même chose que la procédure établissant une connexion standard on change juste le numéro de port et on coche ssl



On tombe sur un message d'erreur, le contrôleur de domaine ne supporte pas LDAPS car il n'est pas associé à un certificat.



Il existe deux méthodes pour activer LDAPS (LDAP sur SSL) sur un contrôleur de domaine :

- Mettre un Certificat Racine sur le contrôleur de domaine en installant une autorité de certification racine sur hermes
- Utiliser un certificat tiers sur le contrôleur de domaine. (Hermes)

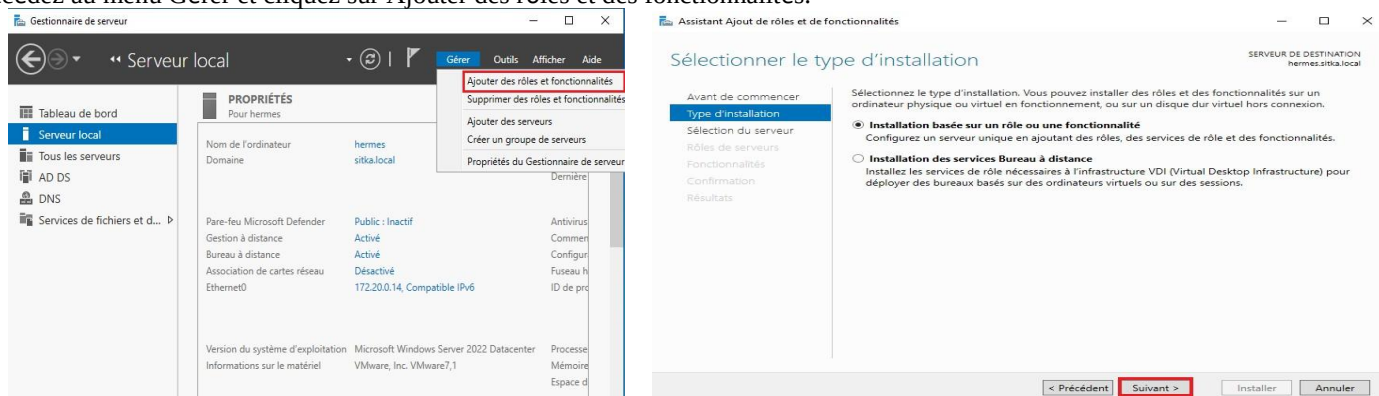
Pour notre procédure on choisira la première méthode, Donc il faut installer une autorité de certification afin de tirer parti de LDAPS

a- Création d'une autorité de certification sur le contrôleur de domaine hermes

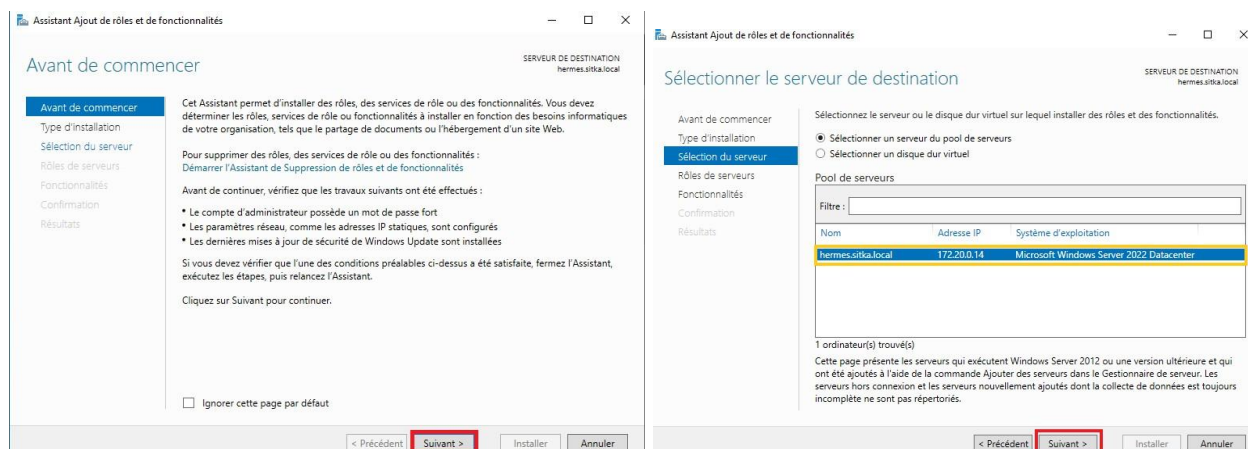
Il est nécessaire d'installer le service autorité de certification. Pour fournir au contrôleur de domaine un certificat qui permettra au service LDAPS d'opérer sur le port 636.

i- Ajouter le rôle certificat sur hermes

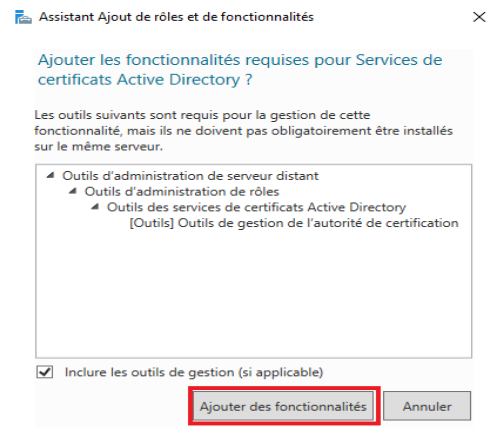
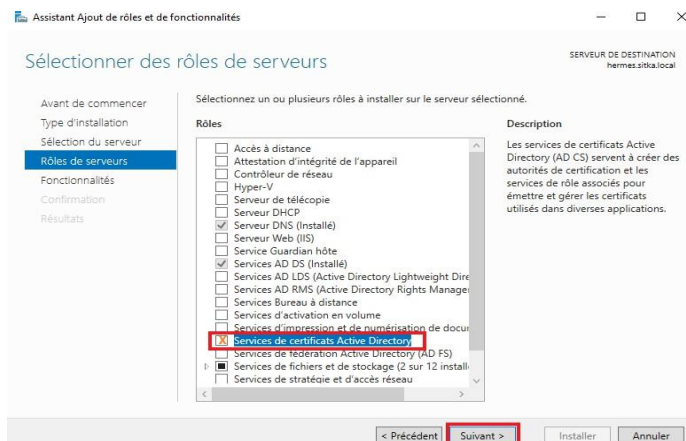
Accédez au menu Gérer et cliquez sur Ajouter des rôles et des fonctionnalités.



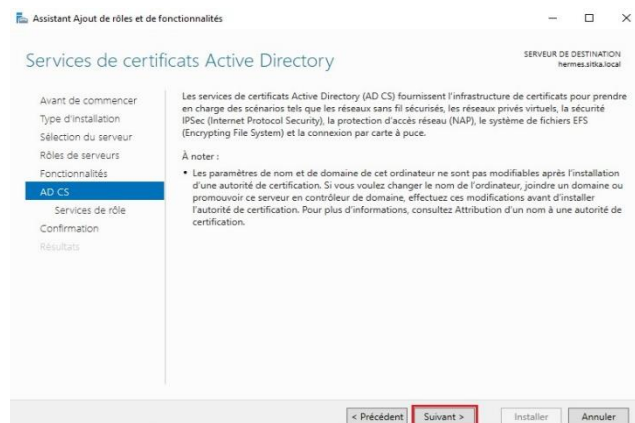
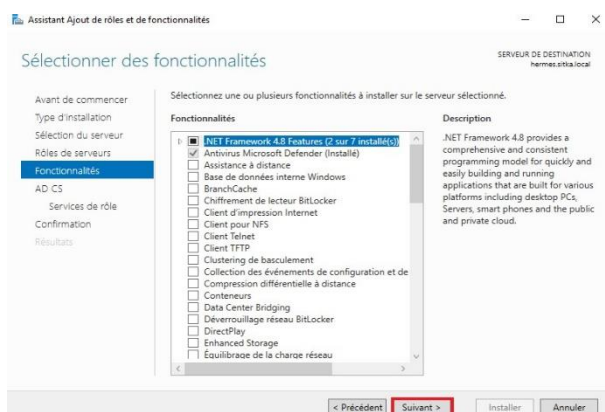
On vérifie le nom et l'adresse IP de notre serveur on clique après sur suivant



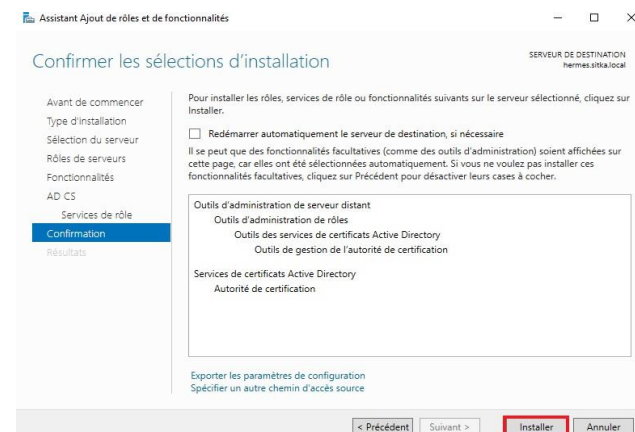
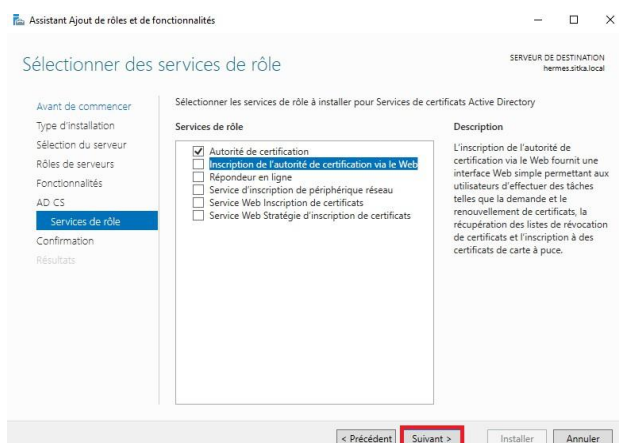
On coche Services de **Certificats Active Directory** et on rejoute les fonctionnalités



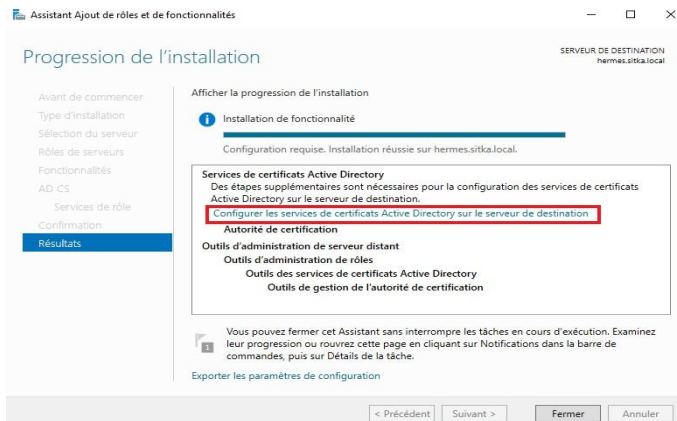
Sur les deux Boites de dialogues ci-dessous on laisse tout par défaut en faisant suivant.



On sélectionne que l'option **Autorité de certification**



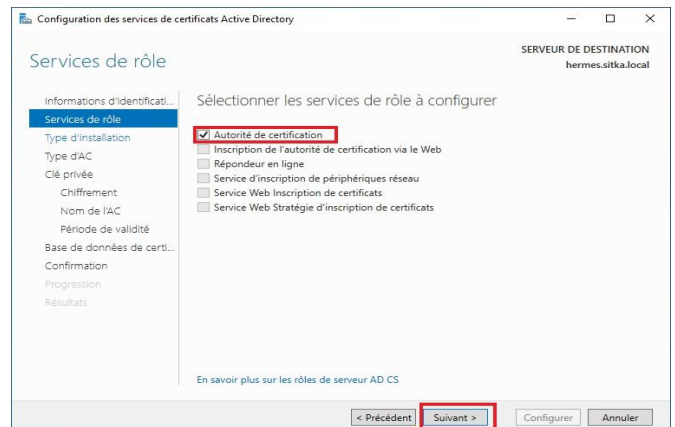
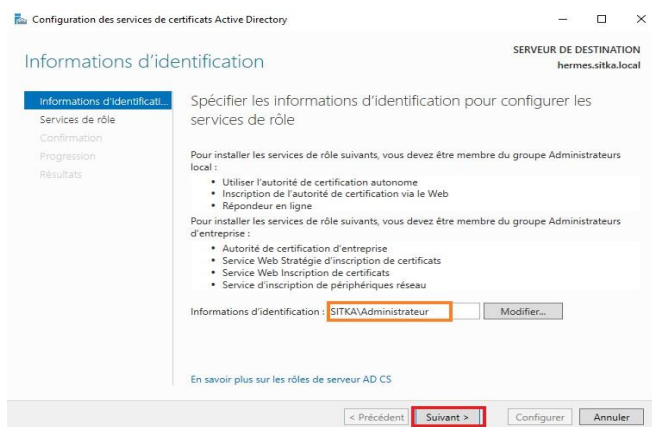
Dernière étape on clique sur le lien **Configurer les services Active Directory sur le serveur de destination**



ii- Configuration du rôle certificat sur hermes

Une fois le rôle certificat est installé il faut maintenant le configurer, on vérifie les informations d'identification, il est obligatoire d'être connecté avec le compte de l'administrateur de l'entreprise (domaine\administrateur).

On coche après Autorité de certification, toutes les autres options on peut les installer après au besoin



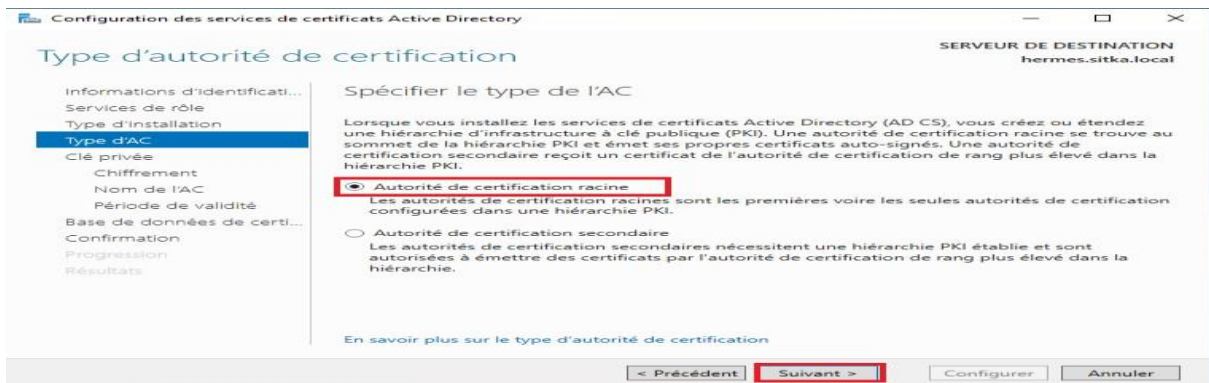
On sélectionne Autorité de certification d'entreprise afin que l'autorité de certification puisse utiliser l'annuaire LDAP



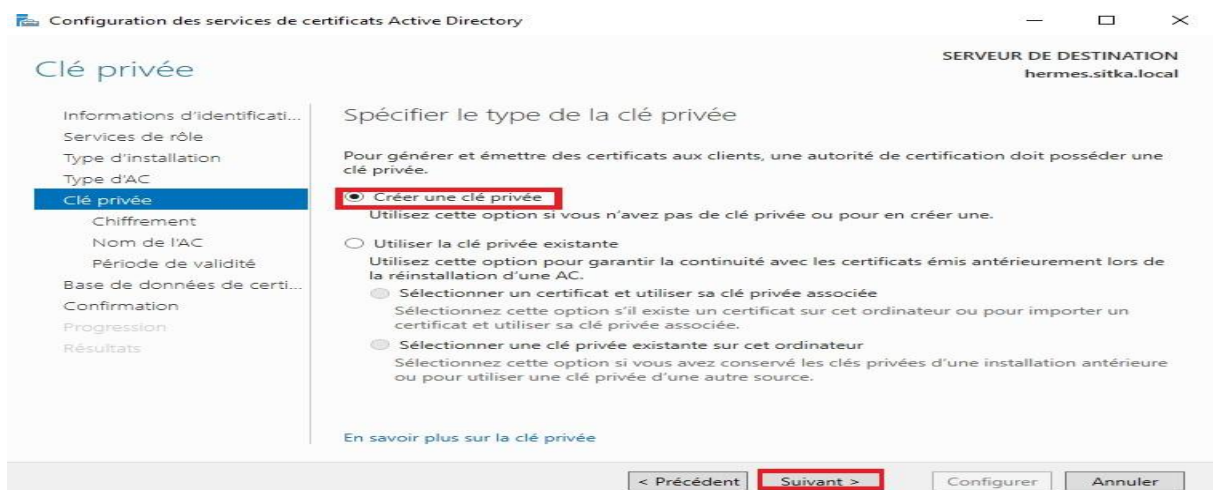
On sélectionne autorité de certification racine

Ce type d'autorité de certification couplé avec un Active Directory est utile pour un intranet mais est déconseillée pour un accès public. Puisque notre autorité n'est pas listée parmi les autorités de certification de

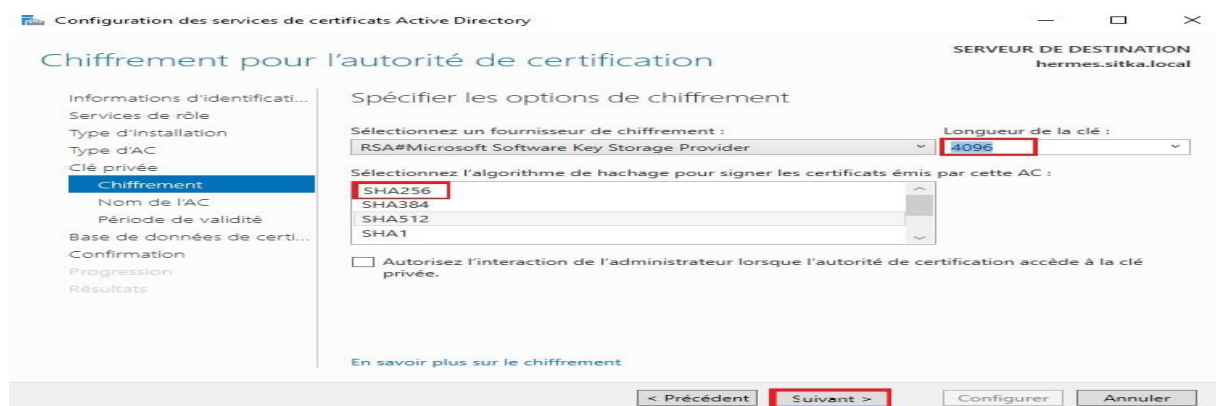
confiance, les personnes utilisant des certificats émis par notre autorité de certification auront un avertissement mentionnant que nos certificats ne sont pas de confiance.



On choisit de créer une clé privée



On choisit nos clés de chiffrement, plus les clés sont longues plus la sécurité est renforcée mais malheureusement les performances vont être impactées.



On peut modifier les valeurs par défaut ; je choisis hermes-CA comme nom commun de ACR

Configuration des services de certificats Active Directory

Nom de l'autorité de certification

SERVEUR DE DESTINATION
hermes.sitka.local

Informations d'identificati...
Services de rôle
Type d'installation
Type d'AC
Clé privée
Chiffrement
Nom de l'AC
Période de validité
Base de données de certi...
Confirmation
Progression
Résultats

Spécifier le nom de l'AC

Tapez un nom commun pour identifier cette autorité de certification. Ce nom est ajouté à tous les certificats émis par l'autorité de certification. Les valeurs des suffixes du nom unique sont générées automatiquement, mais elles sont modifiables.

Nom commun de cette AC :

Suffixe du nom unique :

Aperçu du nom unique :

[En savoir plus sur le nom de l'autorité de certification](#)

< Précédent **Suivant >** Configurer Annuler

On rentre le période de validité pour le certificat de l'ACR., la période de validité du certificat de l'autorité de certification doit dépasser la période de validité des certificats émis.

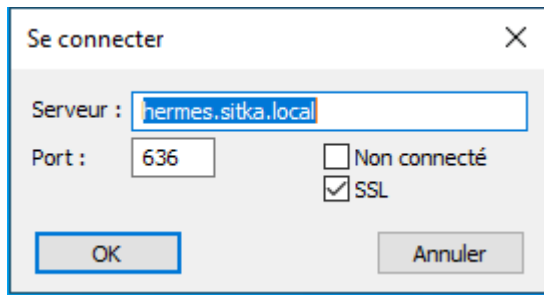
On laisse les dossiers des bases de données et des logs, par défaut.

L'assistant nous affiche un résumé de la configuration choisit, on lance ensuite le processus de Configuration

On doit obtenir le message configuration réussie

On reteste maintenant notre connexion LDAPS à partir de l'explorateur LDAP

La connexion sécurisée utilisant le **ssl** sur le port **636** à la base d'annuaire fonctionne on peut identifier les partitions d'annuaire

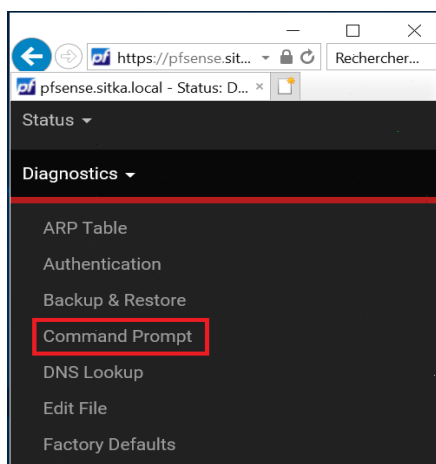


B- Test de la connectivité LDAP et LDAP (LDAP sur SSL) sur heimdall (pfsense)

Sur pfsense on test la connexion de pfsense à la base d'annuaire du controleur de domaine en tapant la commande suivante soit en ssh ou directement sur pfsense:

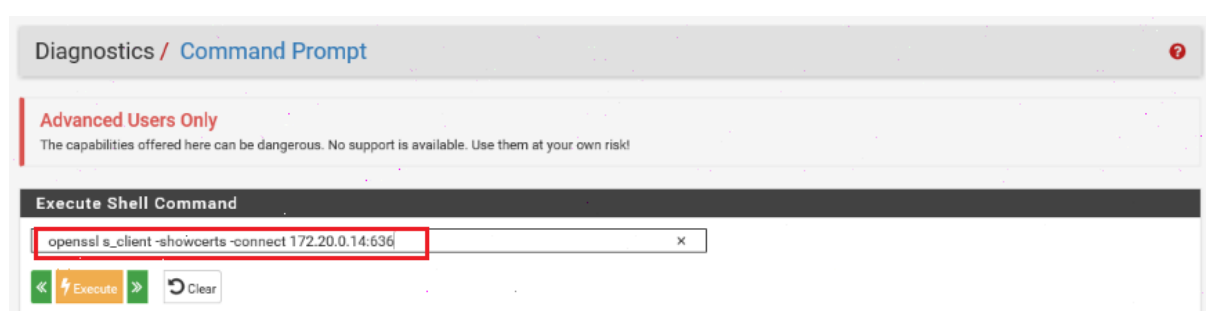
```
# openssl s_client -showcerts -connect 172.20.0.14:636 !less
```

On peut faire la meme chose sur l'interface web de pfsense pour tester la connexion de pfsense à la base d'annuaire du controleur de domaine, donc on va sur **Diagnostics** + **Command Prompt**



On tape la commande suivante :

```
openssl s_client -showcerts -connect hermes.sitka.local:636
```



Le contrôleur de domaine nous envoie le certificat qu'il utilise pour appliquer le ssl

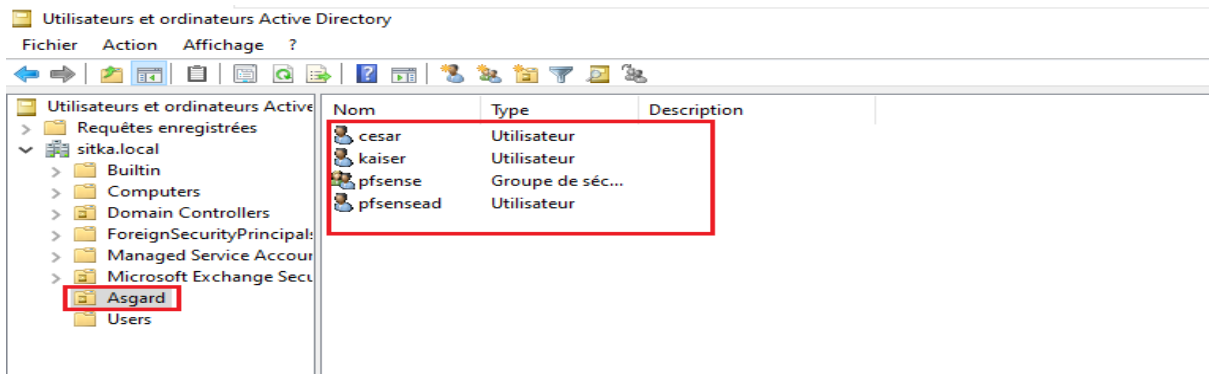
```
Shell Output - openssl s_client -showcerts -connect hermes.sitka.local:636

depth=0 CN = hermes.sitka.local
verify error:num=20:unable to get local issuer certificate
verify return:1
depth=0 CN = hermes.sitka.local
verify error:num=21:unable to verify the first certificate
verify return:1
depth=0 CN = hermes.sitka.local
verify return:1
CONNECTED(00000003)
---
Certificate chain
 0 s:CN = hermes.sitka.local
  i:DC = local, DC = sitka, CN = HERMES-CA
-----BEGIN CERTIFICATE-----
MIIG0zCCBLugAwIBAgITEgAAAAJCXcyFPesdnYgAAAAAAjANBgkqhkiG9w0BAQ0F
ADBCMRUwEwYKKZImiZPyLQGBGRYFbg9jYWwxFtATBgoJkiaJk/IsZAEZFgVzaXRr
YTESMBAQIUEAxMjSEVSTUVTLUNBMB4XDTIyMDAwOTA4NDIzOFoXDTEyMDAwOTA4
NDIzOFwHTeBMBGA1UEAxMSAGVybWVzLnNpdGthLmxvY2FsMIIIBIjANBgkqhkiG
9w0BAQ0FAAOCAQ8AMIIBCgKCAQEAvHs5UeELmjovxUSPf8XRlqDa9gIsff7R10M
42lsBUP67Nya73IUDqYQ8QsQmzaqkgNDqaQXd08Bdq89rbZxa6QIGPHURHr8Edu
ANZxtntbM1c0rCp3RnQS1PDq4mNJ3XvL+IU82oR4nB234mInC6rQa20N/kNw+UwW
EaEDHMgQp1Vc7NvEfJUSY5Cmpioz1x+NQDexH11/EW1h6k5qBPAPj2CUFzTxTB/r
baOpNhI+A6d4fMWRsetDimC6xEhIKy82sZg/+1K2fJzh1FYeTTIBV2jw6qTXq1CA
DTf1adu2E3iXwUmxG2uM6Gbfd0wH6k5OQRrKNxdDQgJD5euLFQIDAQABo4IC5TCC
AueWlwYJKwYBBAQCNxQCBCEIABEAG8ABQ8HAGkAbgBDAG8ABgB0AHIAbwBsAGWA
ZQ8yMB0GA1UdJQQWMBQGCCsGAQUFBwMCBggrBgEFBQcDATAOBGNVHQ8BAf8EBAMC
BAwAwAYJKoZIhvcNAQkPBGswaTA0BgkqhkiG9w0DAgICAIAwDgYIKoZIhvcNAwQC
AgCAMAsGCWCGSFA1AwQBKjALBgglghkgB2QMEAS0wCwYJYIZIAWUDBAECAwQGCW
SAF1AwQBBIABHGUrdgMCBzAKBgkqhkiG9w0DBzAdBgNVHQ4EFgQUg6yhfRd1i31
c8tWc0d/2ineRMwHwYDVR0jBBgwFoAUBV88XfZiRChIBMqLFpBDLkHNF/QwgcYG
A1UdHwSbvjCBuzCBuKCBtaCBsoaBr2xkYXA6Ly8vQ049SEVSTUVTLUNBLENOPWh1
cm11cyxDTj1DRFAsQ049UHVi6G1jJTIwS2V5JTlWU2Vydm1jZXMsQ049U2Vydm1j
ZXMsQ049Q29uZm1ldXJhdGlvbixEQz1zaXRrY5xEQz1sb2NhbD9jZXJ0aWZpY2F0
ZVJldm9jYXRpb25MaXN0P2Jhc2U/b2JqZWNoQ2xhc3M5Y1JMRGlzdHJpYnV0aw9u
JG9pbmQwgbG5GCCsGAQUFBwEBB1GuMIgrMIgoBggrBgEFBQcAoaBm2xkYXA6Ly8v
Q049SEVSTUVTLUNBLENOPUFJQ5xDTj1QdWJsaW1MjBLZXk1MjBTZXJ2aWNLcyxDT
fj1TZXJ2aWNLcyxDTj1Db25maWd1cmF0aW9uLERDPXNpdGthLERDPWxvY2FsP2NB
Q2VydGlmawNhdGU/YmFzZT9vYmplY3RDdGZzc21jZXJ0aWZpY2F0aw9uQXV0aG9y
aXR5MD4GA1UdEQQ3MDWgHwYJKwYBBAQCNxkBoBIEBkH2D9Eay1G10BTfWocpG2C
Emh1cm11cy5zaXRrY55sb2NhbDANBgkqhkiG9w0BAQ0FAAOCAgEAF39BzYd7S5hP
uWyp5C80+YbDONHXcVec1ABJgp2jhMj3itAH4a7TKDXXWbXjNtguBT11IiUzuwuh
jw6Tlw50yjlZ+WUHoJfujuIwInVTjHfmgouH6UP7BwC7KTz+iiwH30HPXVMKixVR
t0EyzZqrS8drkc1i5PfgU1Bj3L8FF3vqK3CVv/Ffd/Uagy+Qfb2WHDmIeCqc6e
IQYnbBNmLcWcqlVgfyE6sybtJ6NLqI8R27JB4QMatrgCB60eiM8GARu6JkGs7jc2
50LzXM4hFVMKberhHdQt4cE77KfG0oGjUmDoJDHDJUGkRWjQQ81W6p59C11d01H
uixAx9k2WTX5zvZIF6WObuw0v4gA+yZOF4+dGn+1+PRpM/Hxcn2VE7UXArVf1m/Y
48KQEE84fCWly/LrVYxi9h0GdbM7pkTrRT0bp1vbUItcyaAVHC06zpx7y2ACGGr0
Xmi99AfKj5ar1RLR6b/8uDFqCTBdc3BVj5ugJ0KxSaISK0tSIrr/tU/KGve6B1G9
5WpOUzEb21+iRd2oT62tyPQ061BsRktBLFSyPjio1jrH/PKNP//FLMFAjAfhqa1p
aAg1j5ETCwdR4ELyzB2kEMJUrRHxuutckNq8brhGZSdKUGAA5mh1vMr/bVTFClw
WAHDHExmYpTKPz51F6Flno10BSy1LM=
-----END CERTIFICATE-----
```

C- Création des comptes utilisateurs sur le contrôleur de domaine

Sur le contrôleur de domaine je crée :

- Un groupe **pfsense**
- Un utilisateur **kaiser** faisant partie du groupe **pfsense**
- Un utilisateur **cesar** faisant partie du groupe **pfsense**
- Un utilisateur **pfsensead** faisant partie du groupe **pfsense** et qui va servir de faire la liaison entre pfsense et le contrôleur de domaine



D- Création des authentifications LDAP et LDAPS sur le serveur pfsense

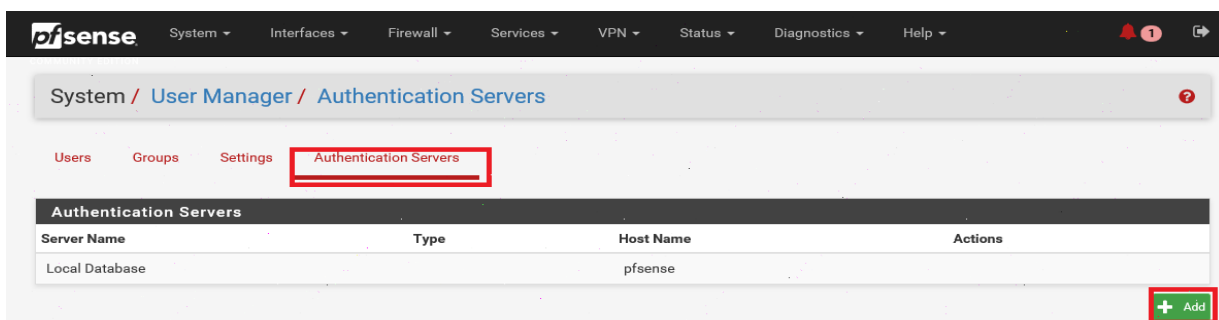
Sur pfsense il existe déjà une base locale permettant l'authentification des utilisateurs.

On va utiliser deux autres méthodes qui permettront l'authentification en utilisant LDAP et LDAPS

1- Création de l'authentifications LDAP

Maintenant on va créer une authentification LDAP sur pfsense à partir l'interface web on va sur [System / User Manager / Authentication Servers](#)

Et on clique sur  pour rajouter une authentification Servers



On remplit Les champs comme indiqué ci-dessous, les étapes 1,2 et 3 il faut les exécuter à la fin de notre procédure les faire : on tape cn dans le champ **Authentication containers** puis on clique sur **select a container**



Users Groups Settings **Authentication Servers**

Server Settings

Descriptive name

Type

LDAP Server Settings

Hostname or IP address
NOTE: When using SSL/TLS or STARTTLS, this hostname MUST match a Subject Alternative Name (SAN) or the Common Name (CN) of the LDAP server SSL/TLS Certificate.

Port value

Transport

Peer Certificate Authority
This CA is used to validate the LDAP server certificate when 'SSL/TLS Encrypted' or 'STARTTLS Encrypted' Transport is active. This CA must match the CA used by the LDAP server.

Protocol version

Server Timeout
Timeout for LDAP operations (seconds)

Search scope

Select LDAP containers for authentication

Containers

- ☒ OU=Asgard,DC=sitka,DC=local
- ☐ OU=Domain Controllers,DC=sitka,DC=local
- ☐ OU=Microsoft Exchange Security Groups,DC=sitka,DC=local
- ☐ CN=Users,DC=sitka,DC=local

Base DN **3**

Authentication containers **2**

Note: Semi-Colon separated. This will be prepended to the search base dn above or the full container path can be specified containing a dc= component.
Example: CN=Users,DC=example,DC=com or OU=Staff,OU=Freelancers

Extended query ☐ Enable extended query

Bind anonymous ☐ Use anonymous binds to resolve distinguished names

Bind credentials **1**
on clique sur Select a container

User naming attribute

Group naming attribute

Group member attribute

RFC 2307 Groups ☐ LDAP Server uses RFC 2307 style group membership
RFC 2307 style group membership has members listed on the group object rather than using groups listed on user object. Leave unchecked for Active Directory style group membership (RFC 2307bis).

Group Object Class
Object class used for groups in RFC2307 mode. Typically "posixGroup" or "group".

Shell Authentication Group DN
If LDAP server is used for shell authentication, user must be a member of this group and have a valid posixAccount attributes to be able to login.
Example: CN=Remoteshellusers,CN=Users,DC=example,DC=com

UTF8 Encode ☐ UTF8 encode LDAP parameters before sending them to the server.
Required to support international characters, but may not be supported by every LDAP server.

Username Alterations ☐ Do not strip away parts of the username after the @ symbol
e.g. user@host becomes user when unchecked.

Allow unauthenticated bind ☐ Allow unauthenticated bind
Unauthenticated binds are bind with an existing login but with an empty password. Some LDAP servers (Microsoft AD) allow this type of bind without any possibility to disable it.

2- Création de l'authentications LDAPS

a- Création du formulaire de l'authentification LDAPS

Users Groups Settings **Authentication Servers**

Server Settings

Descriptive name

Type

LDAP Server Settings

Hostname or IP address
NOTE: When using SSL/TLS or STARTTLS, this hostname MUST match a Subject Alternative Name (SAN) or the Common Name (CN) of the LDAP server SSL/TLS Certificate.

Port value

Transport

Même procédure que l'authentification LDAP sauf pour les champs encadrés en **vert** on fait le choix de **SSL/TLS** et on utilise le port **636**

Dans **authentification containers** on tape cn puis on clique sur 



La boîte de dialogue qui nous permet de choisir l'OU qui héberge nos utilisateurs ne s'ouvre pas en plus on a un message d'erreur qui apparaît en bas de la page

Could not connect to the LDAP server. Please check the LDAP configuration.

b- Analyse avec Wire Shark du trafic pfsense active directory

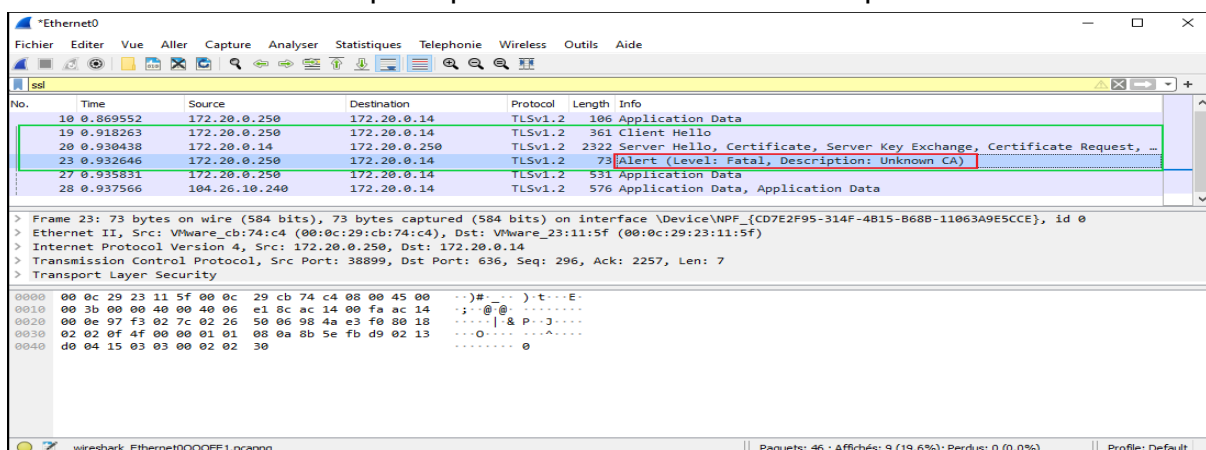
Donc l'authentification LDAPS ne fonctionne pas, on va essayer de faire un diagnostic en faisant une capture de trames avec Wire Shark pour identifier le problème.

On installe Wire Shark sur notre contrôleur de domaine, puis on déclenche une capture de trame en même temps on exécute la manipulation précédente

On fait un filtre ssl/tls dans notre capture de trame

Les trames qui représentent l'échange entre pfsense et le contrôleur de domaine sont encadrée en vert :

- Le dialogue commence par **client hello** la source est pfsense destination le hermes
- Hermes répond par **server hello** et présente son certificat à pfsense
- Pefsense répond par une alerte il ne reconnaît pas le certificat

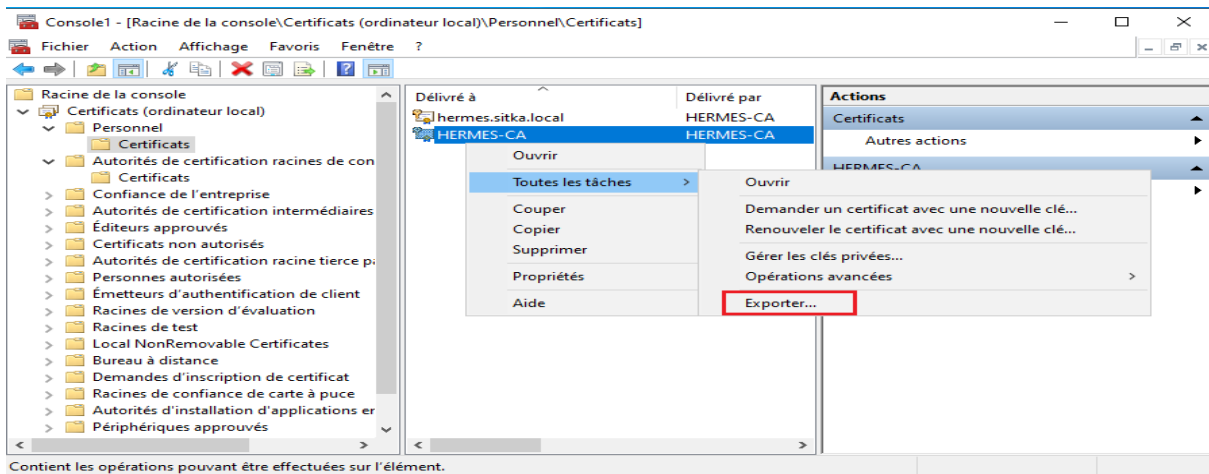


Donc le souci vient du fait que le certificat présenté par Hermes n'est pas reconnu par pfsense **pour contourner ce problème on va importer le certificat de l'autorité de certification racine installée sur hermes sur notre serveur pfsense.**

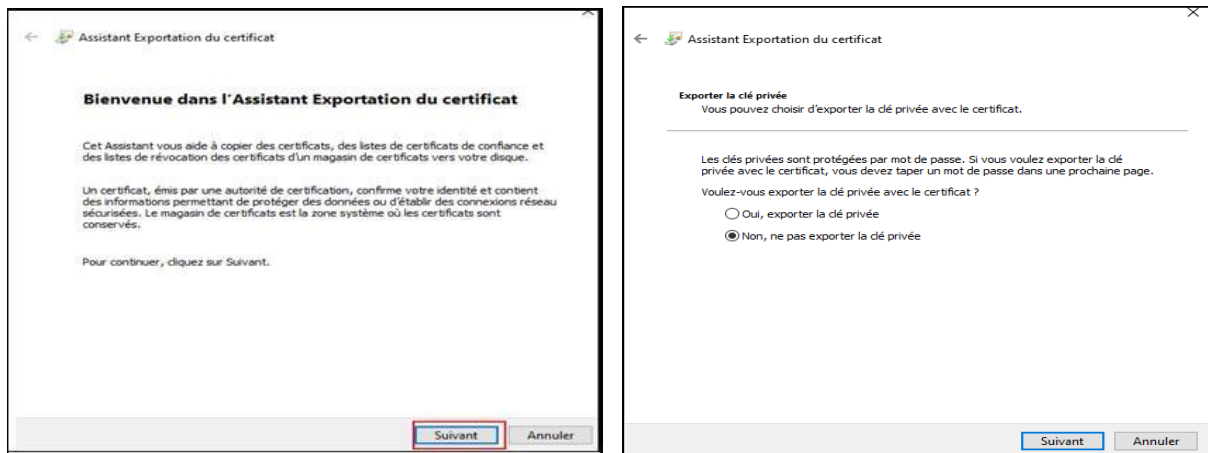
c- Exportation du certificat de l'autorité de certification hermes

- On ouvre une console mmc et on rajoute/Supprimer un composant logiciel enfichable... posant certificat pour ordinateur

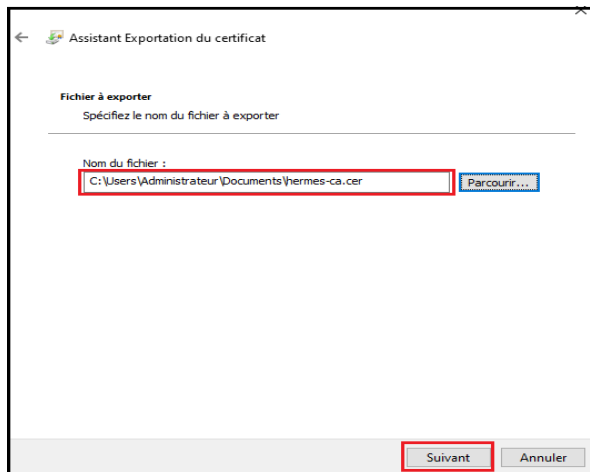
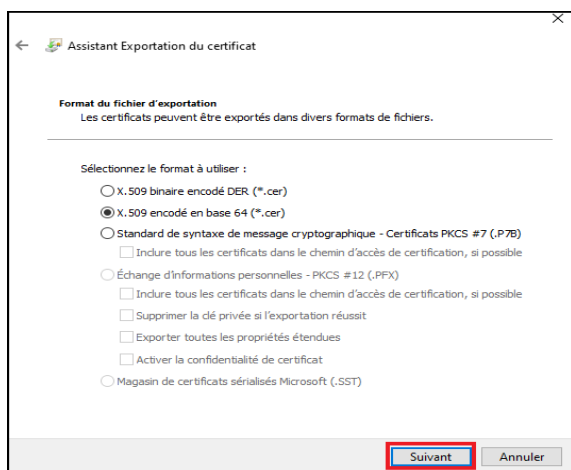
- On exporter le certificat de l'autorité de certification racine au format '.cer' on l'enregistre avec le nom qu'on choisit



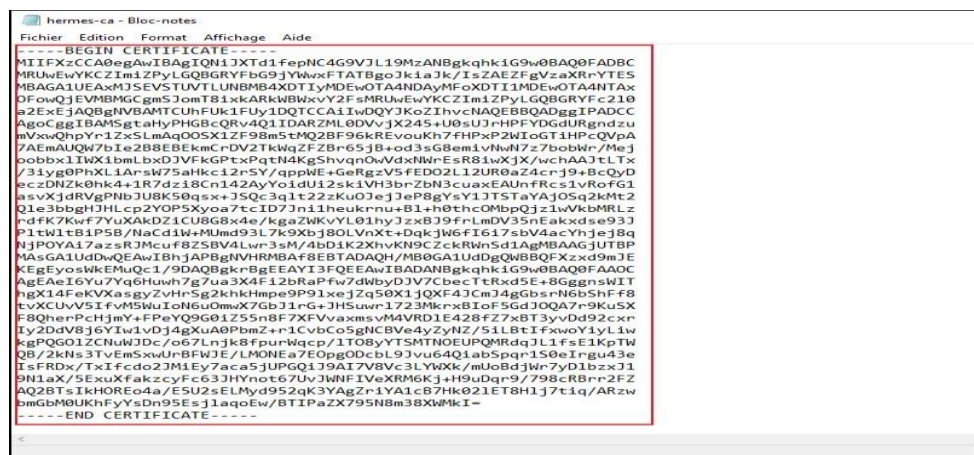
On choisit de ne pas exporter la clé privée.



On choisit le format **X.509 encodé DER (*.cer)** et on l'enregistre avec le nom **hermed-ca.cer**

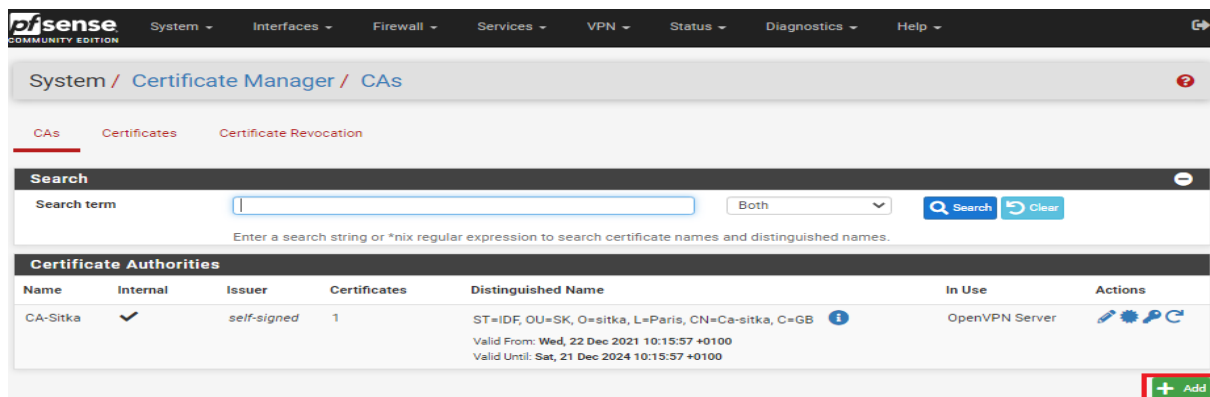


J'ouvre mon fichier hermes-ca.cer avec le bloc note pour afficher le certificat de l'autorité de certification après on le copie pour l'insérer dans pfsense.



d- Importation du certificat de l'autorité de certification racine

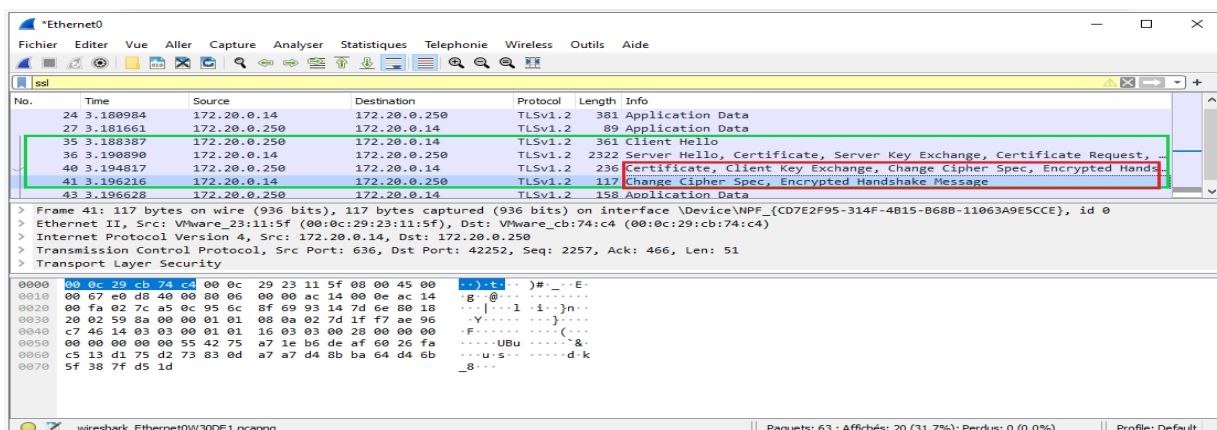
On va sur **certificate manager + Cas** on clique sur ad pour rajouter une autorité de certification.



Après il suffit de coller le certificat de l'autorité de certification racine hermes dans le champ **certificate data**

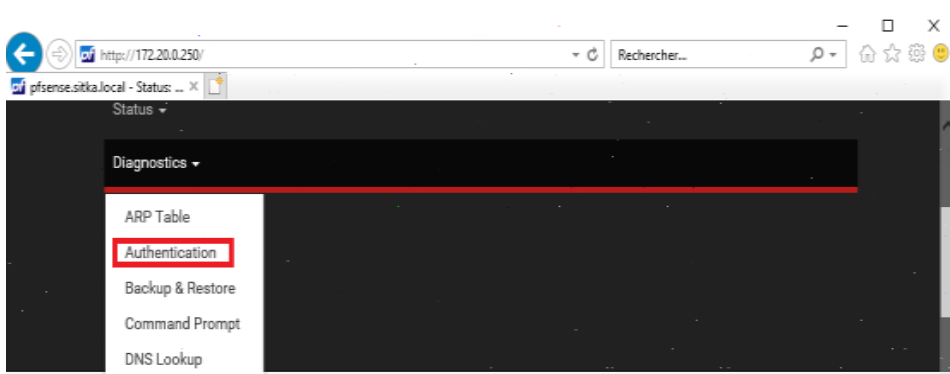
e- Test de la connexion ssl entre pfsense et le contrôleur de domaine

On constate qu'il n'y'a plus de messages d'erreurs que le message handshake (poignée de main) est établie et crypté on peut maintenant revenir pour terminer de remplir notre formulaire authentification LDAPS

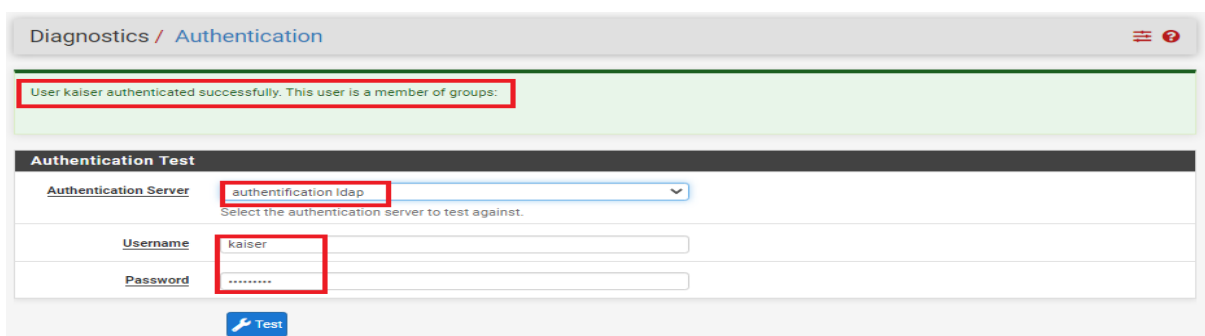


3-Utilisation des authentifications LDAP et LDAPS sur le serveur pfsense

Je vérifie l'authentification Active directory de mon compte **kaiser** à partir de l'interface web de pfsense, on va sur diagnostic + authentification

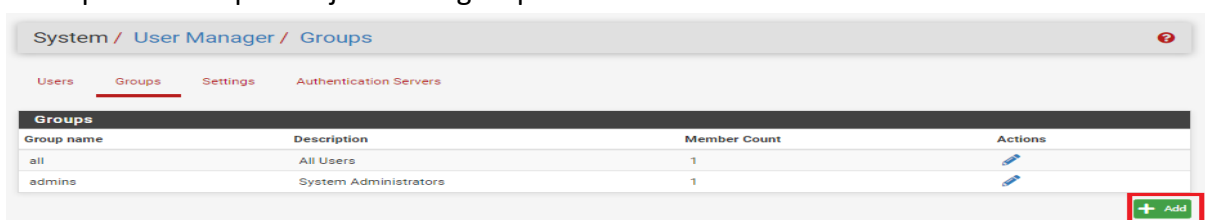


- a- Vérification de l'authentification LDAP et LDAPS
 - L'authentification Active directory en utilisant LDAP a réussi



- a- Configuration des groupes et des utilisateurs sur pfsense

On crée un groupe de même nom que celui créé sur active directory le groupe **pfSense** on clique sur **add** pour rajouter un groupe



On remplit les champs comme indiqué ci-dessous puis on sauvegarde

Users Groups Settings Authentication Servers

Group Properties

Group name:

Scope:
Warning: Changing this setting may affect the local groups file, in which case a reboot may be required for the changes to take effect.

Description:
Group description, for administrative information only

Group membership:
Not members:
Members:

>> Move to "Members" << Move to "Not members"

Hold down CTRL (PC)/COMMAND (Mac) key to select multiple items.

Dès que le groupe est créé je l'édite pour lui donner les droits admin

pfsense compte active directory 0

Dans assigned Privilèges je clique sur add

Assigned Privileges

Name	Description	Action
+ Add		

Je sélectionne **WebCfg – All pages** comme droit

Group Privileges

Group: pfsense

Assigned privileges:

- System - HA node sync
- User - Config: Deny Config Write
- User - Notices: View
- User - Notices: View and Clear
- User - Services: Captive Portal login
- User - System: Copy files (scp)
- User - System: Copy files to home directory (chrooted scp)
- User - System: Shell account access
- User - System: SSH tunneling
- User - VPN: IPsec xauth Dialin
- User - VPN: L2TP Dialin
- User - VPN: PPPoE Dialin
- WebCfg - AJAX: Get Queue Stats
- WebCfg - AJAX: Get Service Providers
- WebCfg - AJAX: Get Stats
- WebCfg - All pages**
- WebCfg - Crash reporter
- WebCfg - Dashboard (all)
- WebCfg - Dashboard widgets (direct access).
- WebCfg - Diagnostics: ARP Table

On remarque le groupe pfsense aura tous les droits

Allow access to all pages (This privilege effectively gives administrator-level access to users in the group)

On enregistre notre configuration

Assigned Privileges

Name	Description	Action
WebCfg - All pages	Allow access to all pages (admin privilege)	Edit
Security notice: Users in this group effectively have administrator-level access		

On fait un test de connexion avec la base LDAP

pfSense

COMMUNITY EDITION

System

Interfaces

Firewall

Services

VPN

Status

Diagnostics

Help

System / User Manager / Settings

Users

Groups

Settings

Authentication Servers

Settings

Session timeout

30

Time in minutes to expire idle management sessions. The default is 4 hours (240 minutes). Enter 0 to never expire sessions. NOTE: This is a security risk!

Authentication Server

authentication ldap

Shell Authentication

☐ Use Authentication Server for Shell Authentication

If RADIUS or LDAP server is selected it is used for console and SSH authentication. Otherwise, the Local Database is used.
To allow logins with RADIUS credentials, equivalent local users with the expected privileges must be created first.
To allow logins with LDAP credentials, Shell Authentication Group DN must be specified on the LDAP server configuration page.

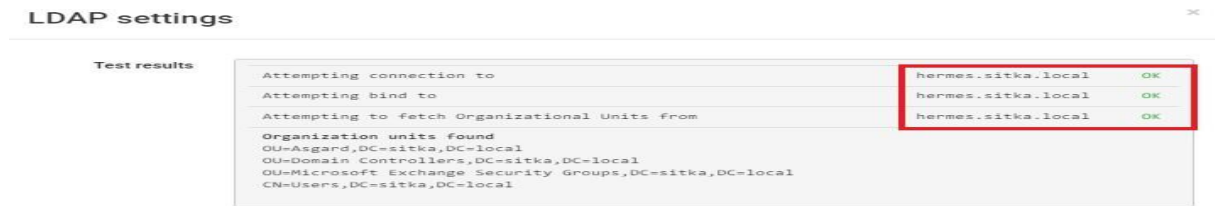
Auth Refresh Time

Time in seconds to cache authentication results. The default is 30 seconds, maximum 3600 (one hour). Shorter times result in more frequent queries to authentication servers.

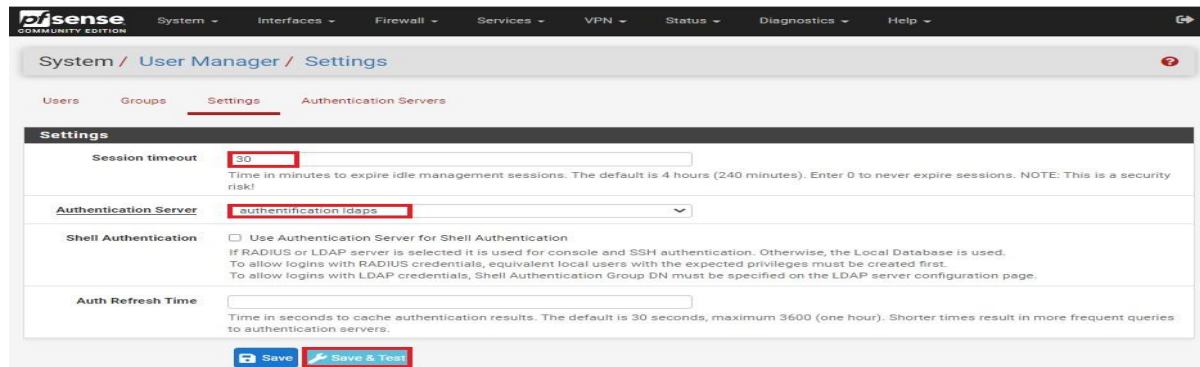
Save

Save & Test

La connexion a réussi



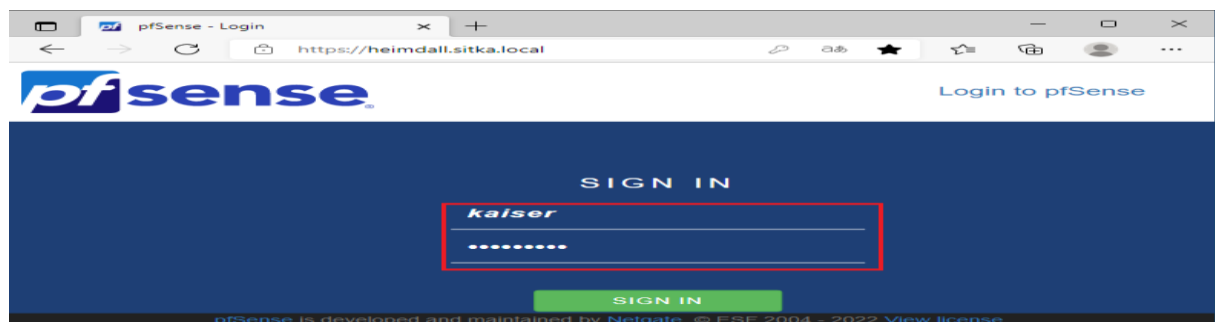
On fait un test de connexion avec la base LDAPS



La connexion a réussi



On teste notre configuration en se connectant avec notre compte **kaiser**



On verifie bien qu'on est connecter avec un compte issue de la base LDAP



